

Migration vers Blog Dynamique (S15)

Architecture de Données, Sécurité PDO et Requêtes Préparées

1. Schéma Relationnel de la Base de Données (SQL)

Cette structure de table optimisée sous InnoDB gère la persistance des articles. L'indexation descendante sur la date de création garantit un traitement ultra-rapide des requêtes de tri pour la navigation.

```
CREATE TABLE IF NOT EXISTS `articles` (  
  `id` INT UNSIGNED AUTO_INCREMENT PRIMARY KEY,  
  `titre` VARCHAR(255) NOT NULL,  
  `slug` VARCHAR(255) NOT NULL UNIQUE,  
  `chapeau` TEXT NOT NULL,  
  `contenu` LONGTEXT NOT NULL,  
  `image_url` VARCHAR(255) DEFAULT NULL,  
  `cree_le` DATETIME DEFAULT CURRENT_TIMESTAMP,  
  `mis_a_jour_le` DATETIME DEFAULT CURRENT_TIMESTAMP ON UPDATE CURRENT_TIMESTAMP,  
  INDEX `idx_cree_le` (`cree_le` DESC)  
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unicode_ci;
```

2. Couche d'Accès aux Données Centralisée via PDO

Configuration de l'instance PDO avec interception des exceptions et désactivation du mode d'émulation pour forcer l'usage des requêtes préparées natives du moteur MySQL.

config/connexion.php

```
<?php  
$host      = 'localhost';  
$db        = 'nom_de_votre_base';  
$user      = 'root';  
$pass      = 'votre_mot_de_passe';  
$charset   = 'utf8mb4';  
  
$dsn = "mysql:host=$host;dbname=$db;charset=$charset";  
  
$options = [  
    PDO::ATTR_ERRMODE           => PDO::ERRMODE_EXCEPTION,  
    PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC,  
    PDO::ATTR_EMULATE_PREPARES  => false,  
];  
  
try {  
    $pdo = new PDO($dsn, $user, $pass, $options);  
} catch (\PDOException $e) {  
    error_log($e->getMessage());  
    die("Une erreur technique est survenue. Veuillez réessayer plus tard.");  
}  
?>
```

3. Flux d’Affichage de l’Accueil (Flux de Navigation)

Remplacement de la structure figée par une boucle itérative. Les URLs de navigation fluide exploitent le paramètre textuel unique (slug).

index.php

```
<?php
require_once 'config/connexion.php';

try {
    $sql = "SELECT id, titre, slug, chapeau, image_url, cree_le FROM articles ORDER BY cree_le DESC";
    $stmt = $pdo->query($sql);
    $articles = $stmt->fetchAll();
} catch (\PDOException $e) {
    error_log($e->getMessage());
    $articles = [];
}
?>
<!DOCTYPE html>
<html lang="fr">
<head>
    <meta charset="UTF-8">
    <title>Mon Blog Dynamique</title>
</head>
<body>
    <main class="container">
        <h1>Derniers Articles</h1>
        <div class="articles-grid">
            <?php if (!empty($articles)): ?>
                <?php foreach ($articles as $article): ?>
                    <article class="card">
                        <h2><?= htmlspecialchars($article['titre']) ?></h2>
                        <p><?= htmlspecialchars($article['chapeau']) ?></p>
                        <a href="article.php?slug=<?= urlencode($article['slug']) ?>">Lire l'article</a>
                    </article>
                <?php endforeach; ?>
            <?php else: ?>
                <p>Aucun article disponible.</p>
            <?php endif; ?>
        </div>
    </main>
</body>
</html>
```

4. Contrôleur d’Affichage unitaire (Requête Préparée Sécurisée)

Sécurisation stricte de l’injection de données issues des requêtes GET. La liaison des paramètres via le moteur de requêtes préparées isole totalement la commande SQL des données utilisateur.

article.php

```

<?php
require_once 'config/connexion.php';

$slug = $_GET['slug'] ?? '';
if (empty($slug)) {
    header('Location: index.php');
    exit;
}

try {
    $sql = "SELECT titre, contenu, image_url, cree_le FROM articles WHERE slug = :slug LIMIT 1";
    $stmt = $pdo->prepare($sql);
    $stmt->execute(['slug' => $slug]);
    $article = $stmt->fetch();
} catch (\PDOException $e) {
    error_log($e->getMessage());
}

if (!$article) {
    http_response_code(404);
    die("<h1>Article introuvable</h1>");
}
?>
<!DOCTYPE html>
<html lang="fr">
<head>
    <meta charset="UTF-8">
    <title><?= htmlspecialchars($article['titre']) ?></title>
</head>
<body>
    <h1><?= htmlspecialchars($article['titre']) ?></h1>
    <div class="content"><?= nl2br(htmlspecialchars($article['contenu'])) ?></div>
</body>
</html>

```

5. Validation des Contraintes Techniques

- **Immunité Injections SQL** : Validation des types et utilisation exclusive des jetons d'exécution via \$pdo->prepare().
- **Neutralisation XSS** : Échappement systématique de l'affichage via la fonction native htmlspecialchars().
- **Performance de Navigation** : Index relationnel unique appliqué sur le slug pour un routage et un requêtage fluide.